

# Upskilling I Linux e Segurança na Cloud

## Segurança em Infraestruturas Cloud

### Sessão 4 I Atividade em grupo

#### **Objetivo:**

Não é fazer hardening avançado, mas definir medidas iniciais coerentes para reduzir a superfície de ataque.

# Relatório do Trabalho de Grupo

## Plano de segurança inicial para um serviço web publicado

### 1. Identificação do Grupo

- Grupo: 8
  - Elementos:
    - Fábio Da Cunha
    - Dénio Melo
    - Sandra Fernandes
    - Luís Miguel
    - Ivandro
- 

### 2. Serviço analisado

**Cenário escolhido:** HTML com Nginx

**Descrição:** Foi publicado um pequeno site estático desenvolvido em HTML e CSS através do servidor web Nginx.

|                          |                                         |
|--------------------------|-----------------------------------------|
| Serviço                  | Site HTML/CSS                           |
| Porta/protocolo          | HTTP- 80                                |
| Servidor web             | Nginx                                   |
| Diretório de publicação  | Var/www/html                            |
| Dependências principais. | Nginx<br>Configuração de rede funcional |

O grupo decidiu continuar com o cenário do site com duas páginas HTML e uma folha de estilos de CSS através do servidor web Nginx, dando continuidade ao tópico anterior.

### 3. Superfície de ataque

| Elemento Exposto | Risco                              | Necessário? | Medida proposta                             |
|------------------|------------------------------------|-------------|---------------------------------------------|
| SSH              | Acesso não autorizado              | Sim         | Limitar o acesso a utilizadores autorizados |
| HTTP             | Tráfico sem encriptação            | Não         | Redirecionar para HTTPS                     |
| HTTPS            | Exploração de vulnerabilidades web | Sim         | Utilizar certificado SSL válido             |
| Base de dados    | Exposição de dados                 | Não         | Não expor externamente                      |
| Diretório web    | Divulgação de ficheiros sensíveis  | Sim         | Aplicar permissões adequadas                |
| WordPress admin  | Ataques de autenticação            | Não         | Não utilizado                               |

### 4. Regras de firewall propostas

| Serviço       | Porta | Decisão   | Justificação                       |
|---------------|-------|-----------|------------------------------------|
| SSH           | 22    | Aberta    | Permitir administração remota      |
| HTTP          | 80    | Aberta    | Permitir direcionamento para HTTPS |
| HTTPS         | 443   | Bloqueado | Não configurado                    |
| MariaDB/MySQL | 3306  | Bloqueado | Não utilizamos                     |

### 5. Medidas de hardening inicial

#### 1. Atualização regular do sistema

Executar atualizações de segurança regularmente.

```
sudo apt update
```

```
sudo apt upgrade
```

#### 2. Rever serviços ativos

Desativar serviços não necessários.

```
systemctl list-units --type=service
```

### 3. Aplicar firewall

Permitir apenas os serviços necessários.

### 4. Rever permissões do diretório web

Garantir que apenas utilizadores autorizados podem modificar ficheiros.

`/var/www/html/`

### 5. Evitar utilização da conta root

Utilizar contas normais com privilégios sudo.

### 6. Proteger acessos remotos

Restringir o acesso SSH e monitorizar tentativas de ligação.

## 6. Plano de validação

| Validação                      | Como fazer        | Resultado esperado                | Evidência                        |
|--------------------------------|-------------------|-----------------------------------|----------------------------------|
| Estado da firewall             | Sudo ufw status   | Firewall activo                   | Output do comando/ print de ecrã |
| Serviço web acessível          | Navegador / curl  | Visualização de página            | Output do comando/ print de ecrã |
| SSH disponível                 | Ssh utilizador@ip | Ligação estabelecida              | Output do comando/ print de ecrã |
| Portas desnecessárias fechadas | ss -tulpn         | Apenas portas necessárias abertas | Output do comando/ print de ecrã |

## 7. Link do repositório GitHub

## 8. Conclusão

O grupo definiu medidas básicas de segurança para reduzir riscos associados à publicação de um serviço web em Linux. As ações propostas permitem proteger o servidor, controlar acessos e preparar futuras melhorias, como a implementação de HTTPS e monitorização contínua.

## Evidencias:

### Instalar nginx

```
root@ubuntu-4gb-nbg1-1:~# sudo apt install nginx -y
Installing:
  nginx

Installing dependencies:
  nginx-common

Suggested packages:
  fcgiwrap nginx-doc ssl-cert

Summary:
  Upgrading: 0, Installing: 2, Removing: 0, Not Upgrading: 0
  Download size: 653 kB
  Space needed: 1853 kB / 74.7 GB available

Get:1 https://mirror.hetzner.com/ubuntu/packages/resolute-updates/main amd64 nginx-common all 1.28.3-2ubuntu1.2 [36.9 kB]
Get:2 https://mirror.hetzner.com/ubuntu/packages/resolute-updates/main amd64 nginx amd64 1.28.3-2ubuntu1.2 [617 kB]
Fetched 653 kB in 0s (12.2 MB/s)
Preconfiguring packages ...
Selecting previously unselected package nginx-common.
(Reading database ... 60361 files and directories currently installed.)
Preparing to unpack .../nginx-common_1.28.3-2ubuntu1.2_all.deb ...
Unpacking nginx-common (1.28.3-2ubuntu1.2) ...
Selecting previously unselected package nginx.
Preparing to unpack .../nginx_1.28.3-2ubuntu1.2_amd64.deb ...
Unpacking nginx (1.28.3-2ubuntu1.2) ...
Setting up nginx-common (1.28.3-2ubuntu1.2) ...
Created symlink '/etc/systemd/system/multi-user.target.wants/nginx.service' → '/usr/lib/systemd/system/nginx.service'.
Setting up nginx (1.28.3-2ubuntu1.2) ...
* Upgrading binary nginx
Processing triggers for man-db (2.13.1-1build1) ...
Processing triggers for ufw (0.36.2-9build1) ...
Scanning processes...
Scanning linux images...

Running kernel seems to be up-to-date.

No services need to be restarted.

No containers need to be restarted.

No user sessions are running outdated binaries.

No VM guests are running outdated hypervisor (qemu) binaries on this host.
root@ubuntu-4gb-nbg1-1:~# [ OK ]
```

### Verificar status:

```
root@ubuntu-4gb-nbg1-1:~# sudo systemctl start nginx
root@ubuntu-4gb-nbg1-1:~# sudo systemctl enable nginx
Synchronizing state of nginx.service with SysV service script with /usr/lib/systemd/systemd-sysv-install.
Executing: /usr/lib/systemd/systemd-sysv-install enable nginx
root@ubuntu-4gb-nbg1-1:~#
```

### Verificar estado de ufw e configurar

```
root@ubuntu-4gb-nbg1-1:~# sudo ufw status
Status: inactive
root@ubuntu-4gb-nbg1-1:~# sudo ufw allow OpenSSH
Rules updated
Rules updated (v6)
root@ubuntu-4gb-nbg1-1:~# sudo ufw allow 'Nginx Full'
Rules updated
Rules updated (v6)
root@ubuntu-4gb-nbg1-1:~# sudo ufw enable
Command may disrupt existing ssh connections. Proceed with operation (y/n)? y
Firewall is active and enabled on system startup
root@ubuntu-4gb-nbg1-1:~# sudo ufw status
Status: active

To Action From
--
OpenSSH ALLOW Anywhere
Nginx Full ALLOW Anywhere
OpenSSH (v6) ALLOW Anywhere (v6)
Nginx Full (v6) ALLOW Anywhere (v6)

root@ubuntu-4gb-nbg1-1:~# sudo ufw status verbose
Status: active
Logging: on (low)
Default: deny (incoming), allow (outgoing), disabled (routed)
New profiles: none

To Action From
--
22/tcp (OpenSSH) ALLOW IN Anywhere
80,443/tcp (Nginx Full) ALLOW IN Anywhere
22/tcp (OpenSSH (v6)) ALLOW IN Anywhere (v6)
80,443/tcp (Nginx Full (v6)) ALLOW IN Anywhere (v6)

root@ubuntu-4gb-nbg1-1:~# sudo ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 127.0.0.1 netmask 255.255.255.255 broadcast 0.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0x10<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 370 bytes 16173 (15.1 KB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 506129 bytes 93598668 (93.5 MB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=7343<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0x10<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 370 bytes 16173 (15.1 KB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 370 bytes 16173 (15.1 KB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

root@ubuntu-4gb-nbg1-1:~#
```

## Regras

```
root@ubuntu-4gb-nbg1-1:~# sudo ufw status verbose
Status: active
Logging: on (low)
Default: deny (incoming), allow (outgoing), disabled (routed)
New profiles: skip

To Action From
--
22/tcp (OpenSSH) ALLOW IN Anywhere
80,443/tcp (Nginx Full) ALLOW IN Anywhere
22/tcp (OpenSSH (v6)) ALLOW IN Anywhere (v6)
80,443/tcp (Nginx Full (v6)) ALLOW IN Anywhere (v6)

root@ubuntu-4gb-nbg1-1:~#
```

Obs: Não foi preciso criar as regras para a base de dados porque não houve necessidade para este trabalho. (não estão instalados mysql e nem postgrees.)

```
root@ubuntu-4gb-nbg1-1:~# mysql
Command 'mysql' not found, but can be installed with:
apt install mariadb-client-core # version 1:11.8.6-5, or
apt install mysql-client-core # version 8.4.9-0ubuntu0.26.04.1
root@ubuntu-4gb-nbg1-1:~# psql
Command 'psql' not found, but can be installed with:
apt install postgresql-client-common
root@ubuntu-4gb-nbg1-1:~#
```

## Instalar lynis - Security Tool for Audit and Hardening Linux Systems

```
root@ubuntu-4gb-nbg1-1:~# sudo apt install lynis
Installing:
lynis

Installing dependencies:
menu

Suggested packages:
apt-listings debsums debsums tripwire scanmail alsa-firmware rsyslog

Summary:
Upgrading: 0, Installing: 2, Removing: 0, Not Upgrading: 0
Download size: 625 kB
Space needed: 3285 kB / 74.7 GB available

Continue? [Y/n] y
Get:1 https://mirror.netrner.com/ubuntu/packages release/universe amd64 lynis all 3.1.6-1 [236 kB]
Get:2 https://mirror.netrner.com/ubuntu/packages release/universe amd64 menu amd64 2.1.5build1 [189 kB]
Fetched 425 kB in 0s (8530 kB/s)
Selecting previously unselected package lynis.
(Reading database ... 69489 files and directories currently installed.)
Preparing to unpack .../archives/lynis_3.1.6-1_all.deb ...
Unpacking lynis (3.1.6-1) ...
Selecting previously unselected package menu.
Preparing to unpack .../menu_2.1.5build1_amd64.deb ...
Unpacking menu (2.1.5build1) ...
Setting up lynis (3.1.6-1) ...
Created symlink '/etc/systemd/system/timers.target.wants/lynis.timer' → '/usr/lib/systemd/system/lynis.timer'.
lynis.service is a disabled or a static unit, not starting it.
Setting up menu (2.1.5build1) ...
Processing triggers for install-info (7.2-Substut2) ...
Processing triggers for man-db (2.13.1-1build1) ...
Processing triggers for man-db (2.13.1-1build1) ...
Scanning processess...
Scanning Linux Images...

Running kernel seems to be up-to-date.

No services need to be restarted.

No containers need to be restarted.

No user sessions are running outdated binaries.

No VM guests are running outdated hypervisor (qemu) binaries on this host.
root@ubuntu-4gb-nbg1-1:~# ls
root@ubuntu-4gb-nbg1-1:~# ./lynis show
-Note: ./lynis: No such file or directory
root@ubuntu-4gb-nbg1-1:~# cd ..
root@ubuntu-4gb-nbg1-1:~# ls
bin boot etc home lib lib64 lost+found media mnt opt proc root run sbin snap src sys usr var
root@ubuntu-4gb-nbg1-1:~# cd -/ lynis
-bash: cd: too many arguments
root@ubuntu-4gb-nbg1-1:~#
```

[illegible]

## Lynis instalado

```

root@ubuntu-4gb-nbgl-1:/usr/sbin# sudo lynis show

Provide an additional argument

lynis show categories
lynis show changelog
lynis show commands
lynis show cdbdir
lynis show details
lynis show environment
lynis show exit
lynis show groups
lynis show help
lynis show hostids
lynis show islemdir
lynis show language
lynis show license
lynis show logfile
lynis show man
lynis show options
lynis show os
lynis show pidfile
lynis show plugindir
lynis show profiles
lynis show release
lynis show relocate
lynis show report
lynis show settings
lynis show tests
lynis show version
lynis show wackdir

Extended help about the show command can be provided with: /usr/sbin/lynis show commands show
root@ubuntu-4gb-nbgl-1:/usr/sbin#
```

## Gardening

## 1. Atualizar pacotes

